

**BKM INDUSTRIES LIMITED**

Data Privacy and Cybersecurity Policy

Document owner	Head – Information Technology / Privacy Officer
Approving authority	Board of Directors
Version	1.0
Effective date	18 th May 2026
Review cycle	Annual

Document control and approval record

Version	1.0	Status	Approved
Prepared for	BKM Industries Limited	Regulatory cut-off	31 July 2026
Recommended by	Board of Directors	Approval date	18 th May 2026
Supersedes	Not Applicable	Next review	Annually

Applicable legal and regulatory framework

This Policy shall be read with the following principal requirements, each as amended, replaced, saved or brought into force from time to time:

- Information Technology Act, 2000 and applicable rules, including the SPDI Rules, 2011, to the extent continuing and applicable
- CERT-In Directions under section 70B(6) of the Information Technology Act, 2000 dated 28 April 2022
- Digital Personal Data Protection Act, 2023 and Digital Personal Data Protection Rules, 2025, in accordance with their notified staged commencement
- Applicable employment, securities, records-retention and contractual confidentiality requirements

STATUTORY OVERRIDE

If this Policy is inconsistent with a mandatory law, regulation, rule, circular, stock-exchange direction or judicial order, the mandatory requirement prevails. A more beneficial statutory employment benefit also prevails.

Purpose and scope

This Policy establishes how BKM Industries Limited protects personal data, confidential information, information systems, networks, devices and technology services throughout their lifecycle. It applies to directors, employees, trainees, contractors, consultants, vendors and every person using Company information or technology, including approved bring-your-own-device arrangements.

Regulatory commencement position

DPDP STAGED COMMENCEMENT

As at 31 July 2026, the principal Data Fiduciary duties and Data Principal rights under the DPDP Act/Rules have a later notified commencement. BKM adopts these controls as a readiness standard; a duty to the Data Protection Board or Data Principals becomes legally operative on its notified date. Current IT Act, SPDI and CERT-In duties remain applicable to the extent provided by law.

Governance and accountability

- The Board oversees material cyber and privacy risk through the committee or governance forum applicable to the Company.
- The Head – IT is responsible for security architecture, access management, incident response, vulnerability management, backup and recovery.
- A Privacy Officer coordinates notices, lawful processing, individual requests, vendor controls and readiness for DPDP commencement. A statutory Data Protection Officer shall be appointed if and when the Company is designated a Significant Data Fiduciary or otherwise required.
- Business owners remain accountable for the necessity, accuracy, access, sharing and retention of data in their processes.

Privacy principles

- Collect and process personal data for a lawful, specific and documented purpose, using consent or another legally permitted basis as applicable on the processing date.
- Provide clear notice and collect only data reasonably necessary for the stated purpose.
- Keep personal data accurate where it is used to make a decision or disclosed to another Data Fiduciary.
- Retain data only for a documented business or legal need, then securely delete or anonymise it unless a legal hold applies.
- Apply reasonable security safeguards appropriate to the sensitivity, volume, context and likely harm.
- Provide accessible grievance and request channels and, once operative, facilitate statutory access, correction, completion, erasure, nomination and consent-withdrawal rights.
- Process children's data and data of a person with a lawful guardian only in accordance with the requirements in force at the relevant time.

Cybersecurity controls

Identity and access: Unique accounts, least privilege, role-based access, multi-factor authentication for material systems, periodic access recertification and prompt revocation on role change or exit.

Assets and configuration: Authorised inventory, supported software, secure configuration, encryption where appropriate, endpoint protection, patching and controlled removable media.

Networks and communications: Segmentation, secure remote access, email and web filtering, monitored administrative access and restricted guest networks.

Data protection: Classification, approved storage and transfer, data-loss controls, clean desk, secure disposal and prohibition on unauthorised personal email/cloud use.

Resilience: Tested backups, recovery objectives, business continuity, incident exercises and supplier continuity arrangements proportionate to risk.

Monitoring: Security logging, alert review, vulnerability assessment, penetration testing where risk warrants, and prompt remediation based on severity.

Third parties and data sharing

- Complete risk-based diligence before granting access to material systems or personal/confidential data.
- Use written terms addressing purpose limitation, confidentiality, safeguards, sub-processors, breach notice, audit/cooperation, retention/deletion and return of data.
- Share only the minimum data required and verify that any cross-border transfer restriction then in force is satisfied.

Incident response and notification

1. Immediately report suspected phishing, malware, unauthorised access, loss of device/data, privacy breach or control bypass to IT through the notified emergency channel.
2. The incident team shall contain, preserve evidence, assess affected systems/data/persons, eradicate, recover and document root cause and corrective action.
3. Specified cyber incidents shall be reported to CERT-In within six hours of noticing or being brought to notice, as applicable; required logs shall be securely maintained for a rolling period of 180 days within India.
4. The Compliance Officer shall assess parallel disclosure to stock exchanges, law enforcement, sector regulators, contractual counterparties and insurers.
5. Notification to the Data Protection Board and affected Data Principals shall be made in the form and timeframe legally applicable after the relevant DPDP provisions commence.

Individual requests and grievances

Requests and grievances may be sent to itsupport@bkmindustries.in or another channel notified by the Company. Identity shall be reasonably verified, responses documented, and statutory timelines applied from their effective date.

Acceptable use and enforcement

- Users must protect credentials, lock devices, use approved software and networks, follow classification rules and complete training.
- Users must not evade controls, share credentials, install unauthorised tools, disclose Company data, conduct unlawful monitoring or use Company systems for unlawful or abusive activity.
- A proportionate investigation and corrective or disciplinary action may follow a breach; good-faith accidental reporting is encouraged and must not be suppressed.

Governance, monitoring and records

- Policy owner: Head – Information Technology / Privacy Officer. The owner shall maintain procedures, registers, evidence and training appropriate to the control risks.
- Functional heads must escalate suspected breaches promptly and cooperate with reviews or investigations.
- Records must be accurate, access-controlled and retained for the longer of the statutory period, an applicable legal hold and the Company's Preservation Policy.
- A person who raises a concern in good faith is protected from retaliation, subject to the Company's whistleblower framework.

Review, approval and controlled disclosure

This Policy shall be reviewed annually and earlier on a material legal, regulatory, operational or organisational change. Amendments require approval by the Board of Directors unless a law permits a delegated, non-substantive update.

This is an internal controlled document. External disclosure is permitted only where required by law or specifically authorised through the Company's disclosure controls.